Cumplimiento normativo ante crisis tecnológicas

Normativa de Ciberseguridad



Nombre del archivo	Cumplimiento normativo ante crisis tecnológicas
Integrantes del grupo	Alexander Cruz Rodriguez y Emilio Moreno Cabrera
Fecha de la versión	22/10/2026
Noticia seleccionada	Múltiples vulnerabilidades en PHP

Índice

1. Investigación y resumen de la noticia....3
2. Análisis del impacto con IA....3
Chatgpt....3
Claude....3
Gemini....3
3. Medidas orientadas al cumplimiento normativo (con IA)....4
Chatgpt....4
Claude....4
Gemini....4
4. Verificación crítica del uso de IA....5
5. Conclusión reflexiva....5

1. Investigación y resumen de la noticia

Las dos nuevas vulnerabilidades críticas de PHP, identificadas como CVE-2026-109618 y CVE-2026-109619, se hicieron públicas el 21 de octubre de 2026. Estos fallos podrían permitir que un atacante ejecute código malicioso en un servidor vulnerable sin necesidad de autenticarse, lo que podría facilitar el robo de información o el control del sistema. El equipo de PHP ha publicado actualizaciones de seguridad para corregirlas y recomienda instalarlas cuanto antes.

Fuentes:

- https://elpais.com/tecnologia/2026-10-21/dos-vulnerabilidades-criticas-detectadas-con-ia-provocan-fallos-multiples-en-miles-de-paginas-web.html
- https://www.incibe.es/incibe-cert/alerta-temprana/avisos/multiples-vulnerabilidades-en-php

2. Análisis del impacto con IA

Prompt:

¿Qué consecuencias pueden tener las nuevas vulnerabili dades de PHP para una empresa y qué problemas legales podrían causar?

Chatgpt

Las vulnerabilidades podrían permitir a los atacantes acceder a los servidores de la empresa, robar o modificar información y provocar pérdidas económicas. Además, podrían perjudicar la reputación de la empresa y, si se filtran datos personales, generar obligaciones legales relacionadas con el RGPD.

Claude

En el plano legal, la empresa puede ser sancionada por el RGPD por no aplicar medidas de seguridad adecuadas, con multas de hasta 10 o 20 millones de euros, o el 2 % o 4 % de su facturación anual. Además, debe notificar la brecha a la AEPD en un máximo de 72 horas, puede enfrentarse a reclamaciones de indemnización de los afectados, a incumplimientos contractuales y sectoriales, y a que su aseguradora de ciberriesgo rechace la cobertura.

Gemini

En el plano legal, exponer datos personales por no aplicar parches vigentes implica sanciones del RGPD de hasta 20 millones de euros o el 4 % de la facturación global, la obligación de notificar la brecha a la AEPD en 72 horas y a los afectados, la indemnización

de daños a los perjudicados, incumplimientos contractuales y la invalidez de la cobertura de la póliza de ciberriesgos por negligencia.

Las tres IA coinciden en que estas vulnerabilidades pueden provocar robos de datos, pérdidas económicas y daños a la reputación. También pueden causar sanciones por incumplir el RGPD. Considero que sus respuestas son útiles, pero algunas afirmaciones necesitan matices: las multas y las notificaciones no se aplican automáticamente en todos los casos, y la cobertura del seguro depende de la póliza. Por eso, es importante contrastar la información con fuentes oficiales, antes de darla por válida.

3. Medidas orientadas al cumplimiento normativo (con IA)

Chatgpt

La empresa debe actualizar PHP, instalar parches de seguridad, proteger los datos, realizar auditorías y formar a los empleados. También debe cumplir el RGPD y tener un plan ante posibles ataques. Estas medidas son realistas, mientras que prometer una seguridad total o eliminar todos los riesgos es inadecuado, porque ningún sistema es completamente seguro.

Claude

Lo coherente es mantener PHP y el software actualizado, auditar vulnerabilidades, formar al personal, tener un protocolo para notificar brechas a la AEPD en 72 horas y controlar accesos y copias de seguridad. Lo inadecuado o irreal es confiar solo en el antivirus, retrasar parches, ocultar brechas o prometer "riesgo cero".

Gemini

Para fortalecer el cumplimiento normativo, las medidas clave son automatizar la aplicación de parches, hacer auditorías de seguridad periódicas, definir un protocolo de notificación de incidentes y asegurar el cumplimiento con proveedores y seguros. En cambio, es irreal e inadecuado reescribir todo el código a otro lenguaje, depender únicamente de un cortafuegos, notificar a las autoridades fallos que no supongan una brecha real o sancionar a los desarrolladores.

En resumen, las medidas adecuadas son automatizar la gestión de parches, realizar auditorías continuas y contar con un protocolo legal de notificación de brechas. Lo irreal o inadecuado es prometer riesgo cero, ocultar incidentes, depender de soluciones superficiales o tomar medidas desproporcionadas como reescribir todo el código.

4. Verificación crítica del uso de IA

Fragmento o idea analizada	Evaluación (Correcta / Dudosa / Errónea)	Evidencia o fuente de contraste
La cobertura del seguro de ciberriesgo puede quedar anulada por negligencia de la empresa.	Dudosa	Claude y Gemini mencionan esta posibilidad, pero no aportan pruebas de que ocurra automáticamente. Depende de las condiciones y exclusiones de cada póliza
Las infracciones del RGPD pueden conllevar multas de hasta 20 millones de euros o el 4 % de la facturación anual global.	Correcta	El artículo 83 del RGPD establece estos límites máximos para determinadas infracciones.
La empresa debe notificar a la AEPD las brechas de datos personales en un máximo de 72 horas.	Correcta	La AEPD confirma el plazo, salvo que sea improbable que la brecha suponga un riesgo para los derechos y libertades de las personas.

5. Conclusión reflexiva

Reflexiona sobre el papel de los sistemas de cumplimiento normativo y la fiabilidad de la IA en su análisis:

Los sistemas de cumplimiento normativo son fundamentales para que una empresa pueda prevenir riesgos, proteger los datos y cumplir con la legislación vigente. En el caso de las vulnerabilidades de PHP, mantener los programas actualizados, realizar auditorías y establecer protocolos de actuación ayuda a reducir los riesgos y evitar posibles consecuencias legales y económicas.

A grandes rasgos, la IA sirve mucho para poder hacer investigaciones generales sobre temas concretos, el problema viene cuando necesitas que los resultados sean más precisos de la cuenta, ya que normalmente suele equivocarse o simplemente cometen errores solamente para poder adherirse a las condiciones que están escritas en el prompt, ya que luego, al investigar solamente un poco los resultados que te da, se pueden empezar a encontrar fallos o medias verdades.